Room8

Datenschutz-Compliance-Bericht 2026

Umfassende Dokumentation der Verarbeitung personenbezogener Daten gemäß der Datenschutz-Grundverordnung (DSGVO, EU 2016/679), des Bundesdatenschutzgesetzes (BDSG) und des Telekommunikation-Telemedien-Datenschutz-Gesetzes (TTDSG).

Version 1.0 · Stand: 11. Mai 2026

Erstellt für die Bachelorarbeit-Präsentation Universität Augsburg

Verantwortlicher: Yusuf Albayrak (Room8 / Yumita)

Management-Zusammenfassung

Dieses Dokument ist die vollständige Datenschutz- und Haftungs-Dokumentation der Plattform **Room8**. Es richtet sich an Aufsichtsbehörden, Hochschul-Prüfer, potenzielle Investoren sowie an unsere Nutzerinnen und Nutzer und beantwortet die folgenden zentralen Fragen:

Was ist Room8?

Room8 ist eine Studierenden-Plattform mit fünf Hauptfunktionen: Wohnungs-Inserate (inkl. Untervermietungen), Marktplatz für gebrauchte Gegenstände, Studi-Jobs, Events und Partner-Coupons. Die Plattform ist bilingual (DE/EN) und über Web (room8.club), iOS- und Android-App verfügbar.

Welche Daten sammeln wir?

Wir erheben das absolute Minimum, um die Plattform zu betreiben: E-Mail, Nutzername, Stadt, Inserat-Inhalte. Keine präzisen Standortdaten, keine biometrischen Daten, keine Gesundheits- oder Glaubens-Informationen. Alle besonderen Datenkategorien gemäß Art. 9 DSGVO sind ausgeschlossen.

Wie schützen wir uns als Plattform-Betreiber?

- **§ 7 Abs. 1 TMG & Art. 14 ECRL (Host-Provider-Privileg):** Wir sind nur Diensteanbieter, keine inhaltliche Prüfung der Inserate
- **§ 10 TMG (Notice-and-Action):** Wir werden erst aktiv, sobald wir Kenntnis von rechtswidrigen Inhalten erlangen — dann binnen 24 h
- **Digital Services Act (DSA, EU 2022/2065):** Als Small-Platform (< 50 Mio. User) gelten reduzierte Pflichten; wir erfüllen sie alle (Trust-Layer, Report-System, transparente Moderations-Logik)
- **Nutzungsbedingungen-Klauseln:** Nutzer versichern, dass sie zur Vermietung berechtigt sind und stellen Room8 von allen Ansprüchen Dritter frei (Indemnification-Klausel)
- **Versicherung:** Empfehlung Cyber-Risiko- und Betriebs-Haftpflicht-Versicherung nach Skalierung

Wer ist juristisch verantwortlich für Wohnungs-Inserate?

> **Klare Antwort:** Der einstellende Nutzer ist allein verantwortlich. Room8 ist ausschließlich Vermittler, kein Vertragspartner. Bei einer unerlaubten Untervermietung (fehlende Zustimmung des Hauptvermieters nach § 540 BGB) trifft die Konsequenzen ausschließlich den Untervermieter — nicht die Plattform.

Welche Risiken bleiben?

Risiko	Eintrittswahrscheinlichkeit	Maßnahme
DSGVO-Bußgeld bei Verstoß	Niedrig	Volle DSGVO-Compliance, AVVs, dokumentierte Löschprozesse
Haftung für illegale User-Inserate	Sehr niedrig	Notice-and-Takedown-Pipeline (Report → 24h-Reaktion)
Rufschädigung durch Missbrauch	Mittel	Trust-Layer, Verifikation, Block-/Report-Funktionen
Datenleck	Niedrig	RLS, Verschlüsselung, JWT-Rotation, Daily Backups
Untermietung ohne Erlaubnis durch Hauptvermieter	Mittel	Klare Disclaimer + Nutzer-Indemnification + Empfehlung Schriftform

Wer haftet wofür — auf einen Blick

Schaden / Pflicht	Wer haftet
Datenschutzverstoß bei Plattform-Daten	Room8 (als Verantwortlicher)
Unerlaubte Untervermietung	Untervermieter (allein)
Falsche Angaben in einem Inserat	Inserent (allein)
Betrug zwischen Nutzern	Der jeweilige Täter (zivilrechtlich + strafrechtlich)
Diskriminierung in Job-Inseraten	Inserierender Arbeitgeber (AGG)
Nicht eingelöste Coupons	Partner-Geschäft
Verletzung des Mindestlohns	Arbeitgeber (MiLoG)
Steuer auf Mieteinnahmen	Vermieter / Untervermieter
Plattform-Down-Time	Room8 (im Rahmen der Verfügbarkeits-SLA, keine Garantie)

Kontakt

Anliegen	E-Mail
Allgemeine Anfragen, Presse	info@roommate.club

Datenschutz-Anfragen, Auskunft, Löschung	help@roommate.club
Beschwerden, Moderation, Rechtliches	admin@roommate.club

Inhaltsverzeichnis

1. Einleitung und Geltungsbereich
2. Verantwortlicher und Kontakt
3. Rechtsgrundlagen der Verarbeitung
4. Übersicht der verarbeiteten Datenkategorien
5. Verarbeitungszwecke im Detail
6. Empfänger und Auftragsverarbeiter
7. Drittlandsübermittlung (US-Datentransfer)
8. Aufbewahrungs- und Löschungsfristen
9. Cookies, lokaler Speicher und Tracking-Technologien
10. Push-Notifications
11. App-Berechtigungen (Kamera, Mikrofon, Standort)
12. Betroffenenrechte gemäß Art. 15–22 DSGVO
13. Technische und organisatorische Sicherheitsmaßnahmen
14. Spezielle Regelungen — Wohnungsplattform & Untervermietung
15. Spezielle Regelungen — Marktplatz, Jobs, Events, Coupons
16. Trust- und Sicherheits-Layer
17. Minderjährigenschutz
18. Beschwerderecht und zuständige Aufsichtsbehörde
19. Änderungen dieser Erklärung
20. Anhang A — Technologie-Stack
21. Anhang B — Auftragsverarbeitungsverträge (AVV-Status)
22. Anhang C — Datenschutz-Folgenabschätzung (DSFA)
23. Anhang D — Muster-Klauseln für Nutzungsbedingungen (Indemnification)
24. Anhang E — Glossar und Abkürzungsverzeichnis

1. Einleitung und Geltungsbereich

Die vorliegende Datenschutz-Compliance-Dokumentation beschreibt umfassend, in welcher Art und Weise die Plattform **Room8** (im Folgenden: „Room8", „wir" oder „die Plattform") personenbezogene Daten ihrer Nutzerinnen und Nutzer erhebt, verarbeitet, speichert und gegebenenfalls an Dritte übermittelt.

Room8 ist eine bilinguale Plattform (Deutsch / Englisch) für Studierende, die folgende Funktionen anbietet:

- **Wohnungen:** Vermittlung von Wohngemeinschafts-Zimmern, Apartments und Untermiet-Angeboten zwischen Studierenden
- **Marktplatz:** An- und Verkauf von gebrauchten Gegenständen (Bücher, Möbel, Elektronik, Fahrräder)
- **Jobs:** Studi-Jobs, Werkstudenten-Stellen, Aushilfsjobs, Praktika
- **Events:** Studi-Partys, Pub-Quizzes, Workshops, Vorträge, Sport-Veranstaltungen
- **Coupons:** Studierenden-Rabatte bei lokalen Partner-Geschäften (Cafés, Bars, Geschäfte, Dienstleister)
- **Chat:** Direkt-Nachrichten zwischen Nutzern auf Basis eines konkreten Inserats
- **Trust-Layer:** Studi-Verifizierung, Block- und Melde-Funktionen, Bewertungen

Die Plattform ist über eine Web-Anwendung (`www.room8.club`) sowie über native Apps für Apple iOS (App Store) und Google Android (Play Store) zugänglich. Die Datenschutzerklärung gilt für sämtliche Zugangswege gleichermaßen.

Rechtsgrundlage dieser Dokumentation: Verordnung (EU) 2016/679 (Datenschutz-Grundverordnung, „DSGVO"), Bundesdatenschutzgesetz (BDSG), Telekommunikation-Telemedien-Datenschutz-Gesetz (TTDSG), § 13 Telemediengesetz (TMG).

2. Verantwortlicher und Kontakt

Verantwortlich für die Datenverarbeitung im Sinne von Art. 4 Nr. 7 DSGVO ist:

Verantwortlicher	Yusuf Albayrak (handelnd unter „Room8" / „Yumita")
Anschrift	Kamelweg 6, 86381 Krumbach, Deutschland
E-Mail (allgemein)	info@roommate.club
E-Mail (Datenschutzanfragen)	help@roommate.club
Telefon	auf Anfrage

Webseite	https://www.room8.club
Datenschutzbeauftragter	Aufgrund der Unternehmensgröße ist gemäß Art. 37 DSGVO i. V. m. § 38 BDSG kein Datenschutzbeauftragter zwingend zu benennen. Datenschutzanfragen werden direkt vom Verantwortlichen bearbeitet.

3. Rechtsgrundlagen der Verarbeitung

Sämtliche Verarbeitungen personenbezogener Daten auf der Plattform Room8 erfolgen ausschließlich auf einer der nachfolgend aufgeführten Rechtsgrundlagen. Die jeweilige Rechtsgrundlage wird in den weiteren Abschnitten dieses Dokuments für jeden Verarbeitungszweck konkret benannt.

Artikel	Anwendungsfall
Art. 6 Abs. 1 lit. a DSGVO *Einwilligung*	Versand von Push-Benachrichtigungen, Setzen nicht-essenzieller Cookies, optionale Marketing-E-Mails, Verarbeitung von Standortinformationen jenseits der angegebenen Stadt.
Art. 6 Abs. 1 lit. b DSGVO *Vertragserfüllung*	Bereitstellung sämtlicher Plattform-Kernfunktionen: Registrierung, Profilverwaltung, Veröffentlichung von Inseraten, Chat zwischen Nutzern, Coupon-Einlösung.
Art. 6 Abs. 1 lit. c DSGVO *Rechtliche Verpflichtung*	Aufbewahrung von Rechnungen und steuerrelevanten Belegen (HGB, AO), Auskunftspflichten gegenüber Strafverfolgungsbehörden, Meldepflichten nach Telemediengesetz.
Art. 6 Abs. 1 lit. f DSGVO *Berechtigte Interessen*	Schutz der Plattform vor Missbrauch, Fehlerprotokollierung (Sentry), Rate-Limiting, Block- und Melde-Funktionen, statistische Auswertung in aggregierter Form.

4. Übersicht der verarbeiteten Datenkategorien

4.1 Registrierungsdaten

Datum	Zweck	Rechtsgrundlage
E-Mail-Adresse	Eindeutige Identifikation, Account-Wiederherstellung, sicherheitsrelevante Mitteilungen	Art. 6 I lit. b
Passwort (gehashed via bcrypt/Argon2)	Authentifizierung	Art. 6 I lit. b
Nutzername	Anzeige in Inseraten und Chat	Art. 6 I lit. b

Vor- und Nachname (optional)	Höflichkeit, Verifizierung gegenüber anderen Nutzern	Art. 6 I lit. b
Studi-Mail-Adresse oder Immatrikulationsnachweis (optional, Verifizierung)	Erhöhung des Trust-Levels (Student-Verified-Badge)	Art. 6 I lit. a
Geburtsdatum (optional)	Altersverifikation, ggf. Anbieten zielgruppenspezifischer Coupons	Art. 6 I lit. a

4.2 Profildaten

- Profilbild (optional, vom Nutzer selbst hochgeladen, gespeichert in Supabase-Storage-Bucket `avatars`)
- Stadt (Pflichtangabe für City-basierte Benachrichtigungen und Listing-Sichtbarkeit)
- Bio / Selbstbeschreibung (optional)
- Studiengang und Hochschule (optional)
- Sprachpräferenz (Deutsch / Englisch)
- Notification-Einstellungen (Push-Toggles pro Kategorie, Quiet-Hours)

4.3 Listing-Daten

Für jedes vom Nutzer veröffentlichte Inserat werden je nach Kategorie folgende Daten verarbeitet:

- **Wohnungen:** Titel, Beschreibung, Stadt, Bezirk, Adresse (optional), Miete, Nebenkosten (optional), Zimmertyp, Verfügbarkeitsdatum, Fotos, Möblierung
- **Marktplatz:** Titel, Beschreibung, Stadt, Preis, Zustand, Fotos, Kategorie
- **Jobs:** Firmenname, Stellenbeschreibung, Anforderungen, Benefits, Vergütung, Arbeitszeit, Bewerbungs-E-Mail/-URL
- **Events:** Titel, Beschreibung, Ort, Adresse, Startzeitpunkt, Endzeitpunkt, maximale Teilnehmerzahl, Preis, Cover-Bild
- **Coupons:** Geschäftsname, Adresse, Telefonnummer, Webseite, Instagram-Handle, Öffnungszeiten, Rabatt-Wert, Einlöse-Bedingungen

4.4 Kommunikationsdaten

- **Chat-Nachrichten:** Sender-ID, Empfänger-ID, Listing-ID (Bezug), Textinhalt, Zeitstempel, Gelesen-Status
- **Bewertungen:** Reviewer-ID, Reviewed-ID, Listing-ID, Sterne-Bewertung, Kommentar, Zeitstempel
- **Reports:** Reporter-ID (anonymisiert nach Verarbeitung), gemeldeter Content/User, Grund, Zeitstempel
- **Coupon-Einlösungen:** User-ID, Coupon-ID, Partner-ID, Zeitstempel, Bestätigungs-Code

4.5 Technische Daten

- **FCM-Tokens** (Firebase Cloud Messaging): gerätespezifische Token zur Zustellung von Push-Benachrichtigungen, gespeichert pro Gerät, automatisch invalidiert bei Token-Rotation
- **IP-Adressen:** in Server-Logs für maximal 30 Tage zur Missbrauchsabwehr (anonymisiert nach 7 Tagen)
- **Browser- und Geräteinformationen:** User-Agent, Betriebssystem, App-Version
- **Authentifizierungs-Tokens (JWT):** Session-Verwaltung, gespeichert im lokalen Speicher des Endgeräts (LocalStorage / Keychain)
- **Fehlerprotokolle (Sentry):** Stack-Traces bei Abstürzen, ohne personenbezogene Daten (E-Mails und Tokens werden via `beforeSend`-Filter entfernt)

4.6 Standortdaten

Room8 verarbeitet **keine präzisen GPS-Koordinaten**. Die Stadt-Information ist eine vom Nutzer aktiv eingegebene Angabe. Es findet kein passives Tracking des aktuellen Aufenthaltsorts statt. Standortbasierte Benachrichtigungen („Neue Wohnung in Augsburg") basieren ausschließlich auf der vom Nutzer angegebenen Heimatstadt.

5. Verarbeitungszwecke im Detail

5.1 Account-Verwaltung

Die Anmeldung erfolgt entweder mittels E-Mail/Passwort, Apple Sign-In oder Google Sign-In. Wir verwenden bei OAuth-Anbietern ausschließlich Standard-Scopes (`email`, `profile`) und speichern keine zusätzlichen Informationen vom Identity-Provider außer dem Klarnamen und der E-Mail.

5.2 Listing-Veröffentlichung

Vom Nutzer veröffentlichte Inserate sind innerhalb der Plattform öffentlich sichtbar. Adressen und Telefonnummern sind nur sichtbar, wenn der Nutzer sie aktiv ins Inserat aufnimmt — eine technische Erkennung oder Vorbefüllung erfolgt nicht.

5.3 Chat zwischen Nutzern

Chat-Nachrichten werden Ende-zu-Ende auf Plattform-Ebene gespeichert (nicht verschlüsselt vom Anbieter — der Plattformbetreiber hat theoretisch Lese-Zugriff zur Missbrauchsabwehr). Sender und Empfänger sehen jeweils ihre Nachrichten, dritte Nutzer haben keinen Zugriff. Bei einem Konto-Löschauftrag werden alle Nachrichten, an denen der Account beteiligt war, gelöscht.

5.4 Coupon-Einlösung

Beim Einlösen eines Coupons wird ein QR-Code generiert, der nur den Coupon-Identifier und einen kurzlebigen Bestätigungs-Code enthält. Der Partner scannt diesen Code in der separaten Partner-Web-App und bestätigt die Einlösung. Eine Übermittlung weiterer personenbezogener Daten an den Partner findet nicht statt.

5.5 Trust-Layer und Missbrauchsabwehr

Zur Wahrung der Sicherheit der Plattform werden folgende Funktionen bereitgestellt:

- **Block-Funktion:** Nutzer können andere Nutzer blockieren. Geblockte Nutzer können den Blockierenden in keinem Inserat sehen, keine Nachrichten senden und keine Bewertungen abgeben.
- **Report-Funktion:** Verstöße können gemeldet werden. Reports werden anonym an die Administration übermittelt und nach Bearbeitung pseudonymisiert.
- **Rate-Limiting:** Übermäßige Aktivität (mehr als 5 Reports pro Stunde, mehr als 30 pro Tag) wird automatisch geblockt.
- **Studi-Verifikation:** Optionale Hochladen von Studi-Ausweis oder Immatrikulationsbescheinigung erhöht das Trust-Level.

6. Empfänger und Auftragsverarbeiter

Room8 bedient sich folgender externer Dienstleister im Rahmen der Auftragsverarbeitung gemäß Art. 28 DSGVO. Mit allen genannten Auftragsverarbeitern wurden Auftragsverarbeitungsverträge (Data Processing Agreements / DPAs) geschlossen.

6.1 Supabase (Datenbank, Authentifizierung, Storage)

Anbieter	Supabase Inc., 970 Toa Payoh North #07-04, Singapur 318992
Verarbeitete Daten	Sämtliche Plattform-Datenbank-Inhalte (User-Accounts, Listings, Chat, Bewertungen, Bilder), Authentifizierung-Sessions
Server-Standort	EU-Region (Frankfurt am Main, Deutschland)
DPA	**Vorhanden** Supabase Data Processing Agreement, Stand 2024
Rechtsgrundlage	Art. 28 DSGVO i. V. m. Art. 6 I lit. b
Zweck	Bereitstellung der Datenbank-Infrastruktur, Authentifizierung, Datei-Speicherung

6.2 Firebase Cloud Messaging (Push-Benachrichtigungen)

Anbieter	Google Ireland Limited, Gordon House, Barrow Street, Dublin 4, Irland (Google Cloud)
Verarbeitete Daten	FCM-Device-Tokens (gerätespezifisch, keine Klaridentifier), Push-Payload (Titel, Body, URL)
Server-Standort	Global (Google Cloud, EU-Sub-Processor in Belgien/Niederlande verfügbar)
DPA	**Vorhanden** Google Cloud Data Processing Addendum, EU-Standardvertragsklauseln
Rechtsgrundlage	Art. 6 I lit. a DSGVO (Einwilligung) — die User stimmt Push-Benachrichtigungen über den Native-Permission-Dialog des Betriebssystems aktiv zu
Zweck	Zustellung von Push-Benachrichtigungen über das jeweilige Betriebssystem

6.3 Vercel (Web-Hosting)

Anbieter	Vercel Inc., 440 N Barranca Avenue #4133, Covina, CA 91723, USA
Verarbeitete Daten	Server-Logs (IP-Adresse, User-Agent, angefragte URL, Zeitstempel, Response-Code)
Server-Standort	Edge-Netzwerk (EU-Region `fra1` Frankfurt für Web-Traffic aus DACH)
DPA	**Vorhanden** Vercel Data Processing Addendum, EU-Standardvertragsklauseln
Rechtsgrundlage	Art. 6 I lit. f DSGVO (berechtigtes Interesse — Bereitstellung der Web-Anwendung)
Zweck	Hosting der Web-Anwendung, Auslieferung statischer Assets

6.4 Resend (transaktionale E-Mails)

Anbieter	Resend, Inc., 2261 Market Street #4408, San Francisco, CA 94114, USA
Verarbeitete Daten	E-Mail-Adresse des Empfängers, Inhalt der E-Mail (Account-Bestätigung, Passwort-Reset, Benachrichtigungen)
Server-Standort	USA
DPA	**Zu prüfen** Resend Privacy & Security Page, EU-Standardvertragsklauseln in Erstellung
Rechtsgrundlage	Art. 6 I lit. b DSGVO (Vertragserfüllung)
Zweck	Versand transaktionaler E-Mails (Account-Bestätigung, Passwort-Reset, kritische Benachrichtigungen)

6.5 Sentry (Fehlerprotokollierung)

Anbieter	Functional Software, Inc. d/b/a Sentry, 45 Fremont Street, 8th Floor, San Francisco, CA 94105, USA
Verarbeitete Daten	Stack-Traces bei Abstürzen, Browser-User-Agent, Plattform-Version
Konfiguration	PII-Filter aktiv (E-Mails, Access-Tokens, Refresh-Tokens werden via `beforeSend` entfernt), Trace-Sample-Rate 0, Session-Replay-Sample-Rate 0
Server-Standort	EU-Region (Frankfurt am Main)

DPA	**Vorhanden** Sentry Data Processing Agreement
Rechtsgrundlage	Art. 6 I lit. f DSGVO (berechtigtes Interesse — Fehlerdiagnose und Stabilität)

6.6 Apple (App Store Distribution, Sign-In)

Anbieter	Apple Inc. / Apple Distribution International, Hollyhill Industrial Estate, Hollyhill, Cork, Irland
Verarbeitete Daten	Bei Sign-In: Apple-ID-spezifische E-Mail (auf Wunsch des Users auch private Relay-Adresse), Klarname
DPA	**Vorhanden** Apple Developer Program License Agreement
Rechtsgrundlage	Art. 6 I lit. b DSGVO

6.7 Google (Play Store Distribution, Sign-In)

Anbieter	Google Ireland Limited, Gordon House, Barrow Street, Dublin 4, Irland
Verarbeitete Daten	Bei Sign-In: Google-Account-E-Mail, Klarname, Profilbild-URL
DPA	**Vorhanden** Google Cloud Data Processing Addendum
Rechtsgrundlage	Art. 6 I lit. b DSGVO

7. Drittlandsübermittlung (US-Datentransfer)

Sofern personenbezogene Daten in die USA übermittelt werden (insbesondere bei Vercel, Resend und Sentry mit Backup-Region USA), erfolgt dies auf Basis der folgenden Rechtsgrundlagen:

- **EU-US Data Privacy Framework (DPF):** Ergänzend zur DSGVO bestätigt seit Juli 2023, dass zertifizierte US-Unternehmen ein angemessenes Schutzniveau gewährleisten. Wir bevorzugen DPF-zertifizierte Anbieter.
- **EU-Standardvertragsklauseln (SCC):** Mit allen US-Auftragsverarbeitern wurden die EU-Standardvertragsklauseln (Module 2 — Verantwortlicher zu Auftragsverarbeiter) gemäß Beschluss der Europäischen Kommission 2021/914 abgeschlossen.
- **Zusätzliche technische Maßnahmen:** Transport-Verschlüsselung (TLS 1.3), Verschlüsselung at-rest (AES-256), pseudonymisierte Identifier, beschränkte Zugriffsrechte.

> **Hinweis zur Risikobewertung:** Nutzer werden ausdrücklich darauf hingewiesen, dass trotz aller Schutzmaßnahmen ein Restrisiko bei der Übermittlung in die USA besteht, insbesondere aufgrund weitreichender Zugriffsbefugnisse amerikanischer Geheimdienste (FISA Sec. 702, Executive Order 12333). Sollten Nutzer dieses Risiko vermeiden wollen, können sie alternativ ausschließlich die Web-Anwendung verwenden, die auf EU-Servern gehostet ist, und auf Apple/Google-Sign-In sowie Push-Benachrichtigungen verzichten.

8. Aufbewahrungs- und Löschungsfristen

Datenkategorie	Aufbewahrungsdauer	Rechtsgrundlage
Account-Daten	So lange der Account aktiv ist + 30 Tage Karenz nach Löschauftrag	Art. 17 DSGVO
Inseratsdaten	So lange das Inserat aktiv ist; nach Deaktivierung 90 Tage	Art. 6 I lit. b
Chat-Nachrichten	So lange beide Gesprächspartner aktiv sind	Art. 6 I lit. b
Server-Logs (IP, User-Agent)	30 Tage, IP-anonymisiert nach 7 Tagen	Art. 6 I lit. f
Fehlerprotokolle (Sentry)	90 Tage rollend	Art. 6 I lit. f
Push-Notification-Logs	30 Tage zu statistischen Zwecken	Art. 6 I lit. f
Reports und Moderations-Aktionen	3 Jahre (Beweismittel bei wiederkehrendem Missbrauch)	Art. 6 I lit. f

Steuerlich relevante Belege	10 Jahre gemäß § 257 HGB, § 147 AO	Art. 6 I lit. c

9. Cookies, lokaler Speicher und Tracking-Technologien

Room8 unterscheidet strikt zwischen technisch notwendigen und nicht-notwendigen Speicher-Technologien. Nicht-notwendige Cookies werden ausschließlich nach ausdrücklicher Einwilligung des Nutzers gesetzt (Opt-In gemäß § 25 Abs. 1 TTDSG).

9.1 Technisch notwendige Speicher-Inhalte

Diese sind essenziell für den Betrieb der Plattform und werden ohne Einwilligung gesetzt (Rechtsgrundlage: § 25 Abs. 2 Nr. 2 TTDSG, Art. 6 I lit. b DSGVO):

Name / Schlüssel	Speicherort	Zweck	Speicherdauer
`sb-tvnvmogaqmduzcycmvby-auth-token`	LocalStorage	Authentifizierungs-Token (JWT)	1 Stunde (Auto-Refresh)
`room8_language`	LocalStorage	Spracheinstellung (de / en)	persistent
`room8_user_id`	SessionStorage	Caching der User-ID innerhalb einer Session	Tab-Lebensdauer
`room8_pwa_dismissed`	LocalStorage	Speichert, ob der PWA-Install-Hinweis bereits weggeklickt wurde	persistent

9.2 Nicht-notwendige Cookies und Speicher-Inhalte (Opt-In)

Diese werden ausschließlich nach aktiver Zustimmung über das Cookie-Banner gesetzt:

Name	Anbieter	Zweck	Speicherdauer
Sentry Session-ID	Sentry	Fehlerprotokollierung und Performance-Monitoring	Tab-Session
Push-Notification-Token	Firebase	Geräte-Identifikation für Push-Zustellung	persistent, bis Token-Rotation

9.3 Cookie-Banner und Widerruf

Beim ersten Besuch der Web-Anwendung wird ein Cookie-Banner angezeigt, das eine differenzierte Auswahl ermöglicht (Alle akzeptieren / Nur notwendige / Einzeln auswählen). Die Auswahl kann jederzeit über den Link *„Cookie-Einstellungen ändern"* im Footer angepasst werden. Ein einmal

erteilter Widerruf gilt sofort und führt zur unverzüglichen Löschung der entsprechenden Speicher-Inhalte.

10. Push-Notifications

Push-Benachrichtigungen werden ausschließlich nach aktiver Zustimmung des Nutzers über den nativen Permission-Dialog des Betriebssystems (iOS, Android) bzw. der Web Push API zugestellt. Eine vorherige Einwilligung ist Voraussetzung (Art. 6 I lit. a DSGVO).

Im Detail werden folgende Benachrichtigungs-Kategorien unterschieden, die individuell in den Notification-Einstellungen aktiviert oder deaktiviert werden können:

- **Chat-Nachrichten:** Neue Nachricht zu einem Inserat
- **City-Listings:** Neue Wohnung / Job / Coupon in deiner Stadt
- **Favoriten:** Jemand hat dein Inserat favorisiert
- **Bewertungen:** Du hast eine neue Bewertung erhalten
- **Bewerbungen:** Jemand interessiert sich für deinen Job
- **Coupon-Einlösungen:** Real-time Bestätigung beim Partner-Scan
- **System-Nachrichten:** Wichtige Sicherheits- und Servicemitteilungen

Quiet-Hours können konfiguriert werden (Standard: 22:00–07:00 Uhr werden keine Push-Benachrichtigungen zugestellt, kritische System-Nachrichten ausgenommen).

11. App-Berechtigungen (Kamera, Mikrofon, Standort)

Berechtigung	Verwendung	Pflicht oder optional?
Kamera	Aufnahme von Profilbildern und Inserats-Fotos	Optional
Foto-Bibliothek	Auswahl bestehender Bilder als Profilbild oder Inserat	Optional
Push-Notifications	Zustellung von Benachrichtigungen	Optional
Standort (präzise)	Nicht angefragt — wird nicht verarbeitet	Nicht aktiv
Mikrofon	Nicht angefragt	Nicht aktiv
Kontakte	Nicht angefragt	Nicht aktiv
Kalender	Nicht angefragt	Nicht aktiv

12. Betroffenenrechte gemäß Art. 15–22 DSGVO

Sämtliche Nutzer haben gegenüber Room8 folgende Rechte hinsichtlich ihrer personenbezogenen Daten:

12.1 Recht auf Auskunft (Art. 15 DSGVO)

Nutzer können jederzeit eine Auskunft über sämtliche zu ihrer Person gespeicherten Daten anfordern. Eine entsprechende Anfrage ist an `help@roommate.club` zu richten. Die Auskunft erfolgt binnen 30 Tagen (Art. 12 Abs. 3 DSGVO).

12.2 Recht auf Berichtigung (Art. 16 DSGVO)

Unrichtige oder unvollständige Daten können in den Profil-Einstellungen direkt korrigiert werden.

12.3 Recht auf Löschung („Recht auf Vergessenwerden", Art. 17 DSGVO)

Über die Option *„Konto löschen"* in den Einstellungen löscht der Nutzer seinen vollständigen Account inklusive sämtlicher von ihm veröffentlichter Inserate, Bilder, Chat-Nachrichten und Bewertungen. Der Vorgang ist unmittelbar und endgültig nach einer Karenz von 30 Tagen.

Technisch geschieht dies in folgenden Schritten:

1. Löschung aller User-eigenen Storage-Objekte (Profilbild, Listing-Fotos, Chat-Anhänge)
2. Löschung sämtlicher Datenbank-Datensätze (Listings, Messages, Reviews, Reports, Saved Searches, Events, Coupons, FCM-Tokens, Notifications, Favorites, Profile-Eintrag)
3. Löschung des Authentifizierungs-Records via Server-seitiger Edge-Function `delete-user`, welche `auth.admin.deleteUser()` aufruft
4. Bestätigung an den Nutzer per E-Mail

Backup-Kopien werden im Rolling-Window von 7 Tagen vorgehalten und nach Ablauf automatisch überschrieben.

12.4 Recht auf Einschränkung der Verarbeitung (Art. 18 DSGVO)

Auf Antrag wird die Verarbeitung bestimmter Daten eingeschränkt, beispielsweise während einer laufenden Beschwerde-Prüfung.

12.5 Recht auf Datenübertragbarkeit (Art. 20 DSGVO)

Nutzer können ihre Daten in einem strukturierten, gängigen und maschinenlesbaren Format (JSON) erhalten. Eine entsprechende Export-Funktion ist in den Einstellungen verfügbar (Roadmap: Phase 2 nach Demo).

12.6 Widerspruchsrecht (Art. 21 DSGVO)

Gegen Verarbeitungen auf Basis von Art. 6 I lit. f DSGVO (berechtigte Interessen) kann jederzeit Widerspruch eingelegt werden.

12.7 Recht auf Beschwerde bei der Aufsichtsbehörde (Art. 77 DSGVO)

Nutzer haben das Recht, sich bei einer Datenschutz-Aufsichtsbehörde zu beschweren. Zuständig ist:

> **Bayerisches Landesamt für Datenschutzaufsicht (BayLDA)**
> Promenade 18, 91522 Ansbach
> Telefon: +49 (0) 981 180093-0
> E-Mail: poststelle@lda.bayern.de
> Webseite: https://www.lda.bayern.de

13. Technische und organisatorische Sicherheitsmaßnahmen (TOMs)

Gemäß Art. 32 DSGVO haben wir geeignete technische und organisatorische Maßnahmen ergriffen, um ein dem Risiko angemessenes Schutzniveau zu gewährleisten. Im Einzelnen:

13.1 Vertraulichkeit

- Row Level Security (RLS) auf sämtlichen Datenbank-Tabellen — User können nur eigene Datensätze sehen / verändern
- Passwörter werden mittels bcrypt (Cost-Factor 12) gehashed gespeichert; Klartext-Passwörter werden zu keinem Zeitpunkt persistiert
- JWT-Tokens haben eine Lebensdauer von maximal 1 Stunde, Refresh-Tokens werden bei jeder Verwendung rotiert
- Zugriffsrechte auf Storage-Buckets sind per Policy auf den jeweiligen Eigentümer beschränkt
- Service-Role-Keys werden ausschließlich serverseitig in Edge-Functions verwendet, niemals an den Client ausgeliefert

13.2 Integrität

- Datenbank-Integritäts-Constraints (Foreign-Keys, Check-Constraints, NOT-NULL)
- Kryptografische Hash-Verifizierung bei Storage-Uploads
- Audit-Logs für administrative Aktionen

13.3 Verfügbarkeit

- Automatische tägliche Backups der Datenbank (Point-in-Time-Recovery für 7 Tage)
- Daily Health-Check via Cron auf Notification-Pipeline
- Sentry-Monitoring auf Anomalien
- CDN-basiertes Hosting mit globaler Verfügbarkeit

13.4 Transport-Verschlüsselung

- TLS 1.3 für sämtliche Web-Requests (HTTPS-only, HSTS-Header gesetzt)
- Certificate-Pinning auf nativen Apps gegen Man-in-the-Middle-Angriffe

13.5 Verschlüsselung at-rest

- Datenbank: AES-256 Encryption auf Storage-Volume-Level
- Storage-Buckets: Server-Side-Encryption

- Backups: AES-256-Verschlüsselung mit Anbieter-managed-Keys

13.6 Trust-Layer-Mechanismen

- Block-Funktion bidirektional, RLS-enforced
- Report-Funktion mit Anti-Trolling-Rate-Limits (5/h, 30/d)
- Studi-Verifikation als optionales Trust-Boost-Feature

14. Spezielle Regelungen — Wohnungs-Plattform und Untervermietung

> **Wichtiger Haftungsausschluss:** Room8 ist ausschließlich eine technische Vermittlungs-Plattform und tritt nicht als Vertragspartei zwischen Vermieter und Mieter / Untermieter auf. Sämtliche rechtlichen, finanziellen und faktischen Konsequenzen einer Wohnungsvermietung oder -untervermietung liegen ausschließlich bei den jeweiligen Nutzern.

14.1 Stellung von Room8

Room8 stellt eine Plattform zur Verfügung, auf der Studierende Wohnungs-Inserate veröffentlichen und Interessenten kontaktieren können. Room8 ist kein Makler im Sinne des § 652 BGB, kein Vermieter und kein Mietvertragspartner. Es findet zu keinem Zeitpunkt eine Prüfung, Validierung oder Empfehlung der angebotenen Wohnungen durch Room8 statt.

14.2 Verantwortlichkeit der Nutzer

Die inserierende Person (Vermieter oder Untervermieter) ist allein und vollumfänglich verantwortlich für:

- Die rechtliche Berechtigung zur Untervermietung (Zustimmung des Hauptvermieters nach § 540 BGB)
- Die korrekte Angabe von Miete, Nebenkosten, Kaution und sonstigen Kosten
- Die Einhaltung mietrechtlicher Vorgaben (insbesondere Mietpreisbremse, ortsübliche Vergleichsmiete, Wohnflächenangabe)
- Die Einhaltung der Wohnraum-Zweckentfremdungsverordnung der jeweiligen Stadt
- Die korrekte Abführung von Einkommensteuer auf Mieteinnahmen
- Die Beachtung des Mieterschutzes (Kündigungsfristen, Mietminderungsrechte, etc.)

14.3 Untervermietung — gesetzliche Pflichten

Untervermietungen sind in Deutschland nur unter bestimmten Voraussetzungen zulässig. Die folgenden Punkte gelten als allgemeine Hinweise, ersetzen jedoch ausdrücklich keine Rechtsberatung:

- **Erlaubnis des Hauptvermieters:** Eine Untervermietung ist gemäß § 540 BGB grundsätzlich nur mit Zustimmung des Hauptvermieters zulässig. Bei „berechtigtem Interesse" (z. B. Auslandssemester) hat der Hauptmieter einen Anspruch auf Erlaubnis (§ 553 BGB), doch dieser muss aktiv eingeholt werden.
- **Zweckentfremdung:** In vielen Großstädten (München, Berlin, Hamburg, Frankfurt) gibt es Zweckentfremdungsverbote — eine kommerzielle Kurzzeit-Untervermietung kann ein Bußgeld nach sich ziehen.
- **Steuerpflicht:** Mieteinnahmen sind grundsätzlich einkommensteuerpflichtig. Bagatell-Grenzen (z. B. 520 € pro Jahr nach altem Recht) wurden in jüngeren Reformen zum Teil angehoben — der jeweils aktuelle Stand ist beim Finanzamt zu erfragen.
- **Anmeldepflicht:** Untermieter müssen sich gemäß Bundesmeldegesetz (§ 17) bei der Gemeinde innerhalb von zwei Wochen anmelden.
- **Versicherung:** Die Hausratversicherung des Hauptmieters deckt in vielen Fällen nicht die Sachen des Untermieters ab.

14.4 Rechtliche Stellung als Host-Provider — keine Haftung für Nutzerinhalte

Room8 nimmt rechtlich die Stellung eines reinen **Host-Providers** gemäß § 10 Telemediengesetz (TMG), Art. 6 Digital Services Act (DSA, Verordnung (EU) 2022/2065) sowie Art. 14 der E-Commerce-Richtlinie (RL 2000/31/EG) ein. Diese gesetzliche Konstruktion ist die zentrale Schutzklausel des Plattform-Betreibers und beruht auf folgenden Grundsätzen:

(a) Keine inhaltliche Prüfung (§ 7 Abs. 2 TMG)

Room8 ist **nicht verpflichtet**, die von den Nutzern eingestellten Inhalte aktiv zu überwachen, sondern darf sich auf eine reaktive Moderation beschränken. Eine generelle Überwachungspflicht ist nach Art. 8 DSA i. V. m. § 7 Abs. 2 TMG ausdrücklich ausgeschlossen.

(b) Haftungsprivileg nach § 10 TMG (Notice-and-Action)

Sofern Room8 zu einem Inserat keine konkrete Kenntnis von einer Rechtsverletzung hat, besteht **keinerlei Haftung** für dessen Inhalt. Ab dem Zeitpunkt einer fundierten Hinweis-Mitteilung („Notice") werden wir den beanstandeten Inhalt zeitnah (Reaktionszeit binnen 24–72 Stunden, in Eilfällen unter 24 Stunden) prüfen und ggf. unverzüglich entfernen oder sperren („Action"). Damit erfüllen wir die Voraussetzungen des Host-Provider-Privilegs.

(c) Implementierung der Notice-and-Action-Pipeline

- **Report-Funktion:** Jeder Nutzer kann ein Inserat oder einen anderen Nutzer mit einem Klick melden. Reports werden in der `reports`-Tabelle gespeichert und triggern eine Push-Benachrichtigung an die Administration.
- **Rate-Limit:** Maximal 5 Reports pro Stunde, 30 pro Tag pro Nutzer — Schutz vor Trolling.
- **Admin-Alert:** Push-Benachrichtigung an Admin in Echtzeit bei eingehenden Reports.

- **Block-Funktion:** Bidirektionale, RLS-enforced Block-Beziehung — geblockte Nutzer sehen den Blockierenden in keinem Inserat.
- **Audit-Log:** Alle Moderations-Aktionen werden protokolliert und drei Jahre lang aufbewahrt.

(d) Digital Services Act (DSA) — als kleine Plattform

Room8 ist im Sinne des DSA eine **kleine Plattform** mit unter 50 Millionen aktiven Nutzern in der EU. Daher gelten die reduzierten Anforderungen gemäß Art. 19 DSA. Die folgenden Pflichten werden aber freiwillig vollumfänglich erfüllt:

- Bereitstellung einer Kontakt-Adresse für Behörden (admin@roommate.club)
- Bereitstellung eines elektronischen Melde-Mechanismus (Report-Funktion, in-App)
- Transparenz der Allgemeinen Geschäftsbedingungen
- Begründungspflicht bei Inhalts-Entfernung gegenüber dem betroffenen Nutzer

(e) Ausdrücklicher Haftungsausschluss

Room8 übernimmt — soweit gesetzlich zulässig — keinerlei Haftung für:

- Die **Richtigkeit** der Angaben in einem Inserat (Wohnungsgröße, Bilder, Miete)
- Die **rechtliche Zulässigkeit** der angebotenen Untervermietung (Hauptvermieter-Erlaubnis, Mietpreisbremse, Zweckentfremdungsverbot)
- **Vermögensschäden** durch Vertragsbruch oder Betrug seitens eines anderen Nutzers
- **Bauliche Mängel** oder gesundheitliche Beeinträchtigungen in der vermieteten Immobilie
- **Konflikte** zwischen Haupt- und Untermieter
- **Strafrechtliche, ordnungsrechtliche oder steuerrechtliche Konsequenzen** einer Vermietung
- **Nicht-Erscheinen** bei Besichtigungen, Diebstahl bei Übergaben, Bedrohungen oder Übergriffe
- **Konkurrierende Mietverhältnisse** (mehrfache Untervermietung derselben Wohnung)

(f) Nutzer-Indemnification (Schadlos-Halte-Klausel)

> In den Nutzungsbedingungen verpflichtet sich jeder Nutzer, der ein Inserat einstellt, ausdrücklich dazu, Room8 von sämtlichen Ansprüchen Dritter freizustellen, die aufgrund einer Rechtsverletzung in seinem Inserat entstehen. Dies umfasst insbesondere:
>
> - Mietrechtliche Streitigkeiten (Klagen des Hauptvermieters)
> - Bußgelder wegen Zweckentfremdungsverstoß
> - Steuer-Nachforderungen
> - Anwaltskosten der Plattform bei Inanspruchnahme
>
> Die genaue Formulierung findet sich in Anhang E dieses Dokuments.

(g) Verbliebene Pflichten der Plattform

Trotz weitgehender Haftungsfreistellung verbleiben für Room8 folgende Pflichten:

- Vorhaltung einer funktionsfähigen Report-Funktion (DSA Art. 16)
- Reaktion auf gemeldete Inhalte binnen angemessener Frist
- Transparente Kommunikation der Moderations-Entscheidungen (DSA Art. 17)
- Beschwerde-Mechanismus für betroffene Nutzer (DSA Art. 20)
- Verbot der Veröffentlichung offensichtlich rechtswidriger Inhalte (z. B. CSAM, Volksverhetzung) — automatische Erkennungs-Tools sind in Planung

14.5 Empfehlungen an die Nutzer

Wir empfehlen jedem Nutzer dringend, vor Abschluss eines Untermietvertrags:

1. Eine schriftliche Erlaubnis des Hauptvermieters einzuholen
2. Einen schriftlichen Untermietvertrag aufzusetzen (Mustervorlagen u. a. beim Deutschen Mieterbund verfügbar)
3. Die Wohnung persönlich zu besichtigen
4. Identität des Vertragspartners zu verifizieren (Personalausweis, Studi-Ausweis)
5. Kaution erst nach Schlüsselübergabe und gegen Quittung zu zahlen
6. Übergabeprotokoll mit Fotos zu erstellen
7. Sich beim Einwohnermeldeamt anzumelden
8. Bei rechtlichen Zweifeln einen Mietrechtsanwalt oder Mieterverein zu konsultieren

15. Spezielle Regelungen — Marktplatz, Jobs, Events, Coupons

15.1 Marktplatz

Room8 ist auch im Marktplatz kein Vertragspartner zwischen Verkäufer und Käufer. Gewährleistungsrechte gelten allein zwischen den vertragschließenden Privatpersonen. Bei gewerblicher Tätigkeit (mehr als gelegentliche Verkäufe) müssen die Nutzer eigenständig die Vorgaben zur Fernabsatz- und Verbraucherinformationspflicht (§ 312d BGB) sowie das Verbraucherrechtegesetz beachten.

15.2 Jobs

Job-Inserate werden ausschließlich vom inserierenden Arbeitgeber eingestellt. Die Verantwortung für die Einhaltung des Allgemeinen Gleichbehandlungsgesetzes (AGG), Mindestlohngesetzes (MiLoG), Arbeitszeitgesetzes (ArbZG) sowie Sozialversicherungspflichten liegt ausschließlich beim Arbeitgeber. Room8 prüft Inserate nicht inhaltlich.

15.3 Events

Veranstalter sind eigenverantwortlich für die Einhaltung der Versammlungs-, Gaststätten-, Lärmschutz- und Jugendschutzvorschriften. Bei Verkauf von Eintrittskarten oder Getränken können steuer- oder gewerberechtliche Pflichten entstehen.

15.4 Coupons

Coupon-Anbieter (Geschäfte, Restaurants, Bars) tragen die Verantwortung für die Einlösbarkeit, die rechtlich konforme Bewerbung (Preisangabenverordnung) und die korrekte steuerliche Behandlung gewährter Rabatte.

16. Trust- und Sicherheits-Layer

Zur Erhöhung der Sicherheit der Nutzer hat Room8 folgende Mechanismen implementiert:

Funktion	Beschreibung	Status
Studi-Verifikation	Optionaler Upload Studi-Ausweis / Immatrikulationsbescheinigung — erhöht Trust-Badge	Live
Bidirektionaler Block	Geblockte User sehen keine Inserate, können keine Nachrichten senden	Live
Report-System	Inhalte und Profile melden; Anti-Trolling-Rate-Limit 5/h, 30/d	Live

Bewertungs-System	Bewertungen nur nach echtem Kontakt (Chat-Nachweis erforderlich)	Live
Admin-Alerts	Push-Benachrichtigung an Admin bei Reports, Verdachts-Aktivitäten	Live
Stadt-Tippfehler-Schutz	Automatische Normalisierung gängiger Tippfehler (z. B. „Augsbrug" → „Augsburg")	Live

17. Minderjährigenschutz

Room8 richtet sich primär an volljährige Studierende. Personen unter 16 Jahren dürfen die Plattform gemäß Art. 8 DSGVO grundsätzlich nicht eigenständig nutzen. Bei der Registrierung wird eine entsprechende Bestätigung abgefragt.

Bei Hinweisen auf eine Nutzung durch Minderjährige (etwa über Reports) wird das Konto unverzüglich gesperrt und nach Verifikation gelöscht. Die Verantwortung für die korrekte Altersangabe liegt beim Nutzer; eine technische Verifikation findet aufgrund datenschutzrechtlicher Verhältnismäßigkeit nicht statt.

18. Beschwerderecht und zuständige Aufsichtsbehörde

Unbeschadet anderer verwaltungsrechtlicher oder gerichtlicher Rechtsbehelfe steht jedem Betroffenen ein Beschwerderecht bei einer Aufsichtsbehörde zu, insbesondere in dem EU-Mitgliedstaat ihres Aufenthaltsorts, ihres Arbeitsplatzes oder des Orts des mutmaßlichen Verstoßes, wenn er der Ansicht ist, dass die Verarbeitung der ihn betreffenden personenbezogenen Daten gegen die DSGVO verstößt (Art. 77 DSGVO).

Für Room8 (Sitz in Krumbach, Bayern) ist zuständig:

> Bayerisches Landesamt für Datenschutzaufsicht (BayLDA)
> Promenade 18, 91522 Ansbach
> Telefon: +49 (0) 981 180093-0
> Telefax: +49 (0) 981 180093-800
> E-Mail: poststelle@lda.bayern.de
> Webseite: https://www.lda.bayern.de

19. Änderungen dieser Erklärung

Wir behalten uns vor, diese Datenschutz-Compliance-Dokumentation anzupassen, sofern sich die Rechtslage, unsere technischen Systeme oder unsere Datenverarbeitungs-Praktiken ändern. Bei wesentlichen Änderungen werden Nutzer per E-Mail oder im Rahmen der nächsten Plattform-Nutzung

aktiv informiert. Die jeweils aktuelle Version ist unter `https://www.room8.club/datenschutz.html` abrufbar.

Anhang A — Technologie-Stack

Komponente	Technologie	Anbieter	Hosting-Region
Datenbank	PostgreSQL 16	Supabase	EU (Frankfurt)
Authentifizierung	Supabase Auth (JWT)	Supabase	EU (Frankfurt)
Object-Storage	Supabase Storage (S3-kompatibel)	Supabase	EU (Frankfurt)
Edge-Funktionen	Deno-Runtime	Supabase	EU (Frankfurt)
Web-Hosting	Vercel Edge Network	Vercel	EU (Frankfurt fra1)
Push-Benachrichtigungen	FCM HTTP v1 API	Google (Firebase)	EU / Global
Transaktional-E-Mails	Resend API	Resend	USA
Fehlerprotokollierung	Sentry SDK + Server	Functional Software, Inc.	EU (Frankfurt)
iOS-Distribution	App Store Connect	Apple Distribution International	EU (Cork, Irland)
Android-Distribution	Google Play Console	Google Ireland Limited	EU (Dublin)
Frontend-Framework	HTML / CSS / JavaScript (Capacitor 7)	Ionic / Eigenentwicklung	n/a

Anhang B — Auftragsverarbeitungsverträge (AVV-Status)

Anbieter	AVV / DPA	SCC für US-Transfer	Status
Supabase	Supabase DPA, Version 2024	n/a (EU-Hosting)	Vorhanden
Firebase / Google Cloud	Google Cloud Data Processing Addendum	EU-SCC Module 2	Vorhanden
Vercel	Vercel DPA, Version 2024	EU-SCC Module 2	Vorhanden

Resend	Resend Privacy Page (DPA in Erstellung)	EU-SCC, DPF-Zertifizierung gewünscht	In Bearbeitung
Sentry	Sentry DPA, Version 2024	EU-SCC Module 2	Vorhanden
Apple Developer	Apple Developer Program License Agreement	EU-SCC (Apple Ireland)	Vorhanden
Google Play / Sign-In	Google Cloud Data Processing Addendum	EU-SCC Module 2	Vorhanden

Anhang C — Datenschutz-Folgenabschätzung (DSFA)

Eine Datenschutz-Folgenabschätzung gemäß Art. 35 DSGVO ist erforderlich, wenn eine Verarbeitung „voraussichtlich ein hohes Risiko für die Rechte und Freiheiten natürlicher Personen zur Folge hat". Für Room8 wurde eine vorgelagerte Schwellwert-Analyse durchgeführt mit folgendem Ergebnis:

Kriterium	Bewertung	Erläuterung
Systematische Bewertung persönlicher Aspekte	Niedrig	Match-Score basiert nur auf User-eigenen gespeicherten Suchen, kein Profiling
Verarbeitung besonderer Datenkategorien (Art. 9)	Keine	Keine Verarbeitung von Gesundheits-, biometrischen, religiösen oder politischen Daten
Systematische Überwachung öffentlicher Bereiche	Nein	n/a
Daten zu strafrechtlichen Verurteilungen	Keine	n/a
Datenverarbeitung in großem Umfang	Niedrig	Im Demo-Stadium < 1.000 User; Skalierungsgrenze 10.000 ohne erneute Bewertung
Datenkombination aus mehreren Quellen	Niedrig	Nur OAuth-Identity + selbst eingegebene Daten
Daten zu schutzbedürftigen Personen	Mittel	Studierende sind in Teilen Minderjährige (< 18, > 16) — gesonderter Schutz
Innovativer Einsatz neuer Technologien	Niedrig	Standard-Web-/Mobile-Stack, keine KI-basierte Entscheidungen
Daten-basierte Entscheidungen mit Rechtsfolge	Keine	Plattform ohne automatisierte Entscheidungen i. S. v. Art. 22 DSGVO

Ergebnis: Eine vollständige Datenschutz-Folgenabschätzung gemäß Art. 35 DSGVO ist zum gegenwärtigen Stand nicht erforderlich. Bei einer Skalierung über 10.000 aktive Nutzer oder Einführung neuer Verarbeitungs-Funktionen (z. B. KI-basierte Match-Empfehlungen, Geo-Tracking) ist eine erneute Bewertung vorzunehmen.

Anhang D — Muster-Klauseln für Nutzungsbedingungen (Indemnification)

Die folgenden Klauseln sind in den Nutzungsbedingungen (AGB) von Room8 enthalten und verlagern die Haftung für eingestellte Inhalte vollständig auf den jeweiligen Nutzer. Sie stellen die juristische Grundlage dafür dar, dass die Plattform für unerlaubte Untervermietungen oder andere Rechtsverletzungen seitens der Nutzer nicht in Anspruch genommen werden kann.

D.1 Eigenverantwortung der Nutzer

> *„Der Nutzer ist allein für die von ihm auf der Plattform eingestellten Inhalte verantwortlich. Er versichert mit dem Einstellen eines Inserats, dass*
> *(a) er zur Veröffentlichung berechtigt ist (insbesondere bei Wohnungen: dass eine etwaige erforderliche Zustimmung des Hauptvermieters gemäß § 540 BGB vorliegt),*
> *(b) alle Angaben wahrheitsgemäß und vollständig sind,*
> *(c) keine Rechte Dritter (insbesondere Urheber-, Marken- oder Persönlichkeitsrechte) verletzt werden,*
> *(d) keine gesetzlichen Vorschriften (insbesondere Mietpreisbremse, Zweckentfremdungsverbot, AGG, Jugendschutz) verletzt werden,*
> *(e) er die steuerlichen Pflichten aus etwaigen Einnahmen selbst erfüllt."*

D.2 Schadlos-Halte-Klausel (Indemnification)

> *„Der Nutzer stellt Room8, seine Geschäftsführer, Mitarbeiter und Beauftragten von sämtlichen Ansprüchen frei, die Dritte aufgrund einer Verletzung dieser Nutzungsbedingungen oder einer Verletzung gesetzlicher Vorschriften durch von ihm eingestellte Inhalte gegenüber Room8 geltend machen. Diese Freistellung umfasst insbesondere Schadensersatz, Anwalts- und Gerichtskosten, Bußgelder sowie steuerliche Nachforderungen. Room8 wird den Nutzer über etwaige Ansprüche unverzüglich informieren, damit dieser bei der Verteidigung mitwirken kann."*

D.3 Notice-and-Takedown-Mitteilung

> *„Wer Inhalte auf der Plattform für rechtswidrig hält, kann diese über die in-App Report-Funktion oder per E-Mail an admin@roommate.club melden. Die Meldung sollte folgende Angaben enthalten: (a) eindeutige Identifikation des beanstandeten Inhalts, (b) konkrete Begründung der Rechtsverletzung, (c) Kontaktdaten des Meldenden. Room8 wird die Meldung binnen 72 Stunden bearbeiten und im Falle einer offensichtlichen Rechtsverletzung den Inhalt unverzüglich entfernen."*

D.4 Beendigung der Plattform-Nutzung

> *„Room8 behält sich vor, einzelne Inhalte oder den gesamten Account eines Nutzers ohne vorherige Ankündigung zu sperren oder zu löschen, wenn (a) wiederholt gegen diese Nutzungsbedingungen verstoßen wurde, (b) eine Behörde dies anordnet, (c) wirtschaftlich begründete Gründe (z. B. Spam, Missbrauch der Plattforminfrastruktur) vorliegen. Der Nutzer wird über die Begründung unterrichtet und hat das Recht auf Widerspruch über admin@roommate.club."*

D.5 Haftungsbeschränkung der Plattform

> *„Room8 haftet — soweit gesetzlich zulässig — nur für Vorsatz und grobe Fahrlässigkeit. Eine Haftung für leichte Fahrlässigkeit ist auf die Verletzung wesentlicher Vertragspflichten (Kardinalpflichten) und auf den vorhersehbaren, vertragstypischen Schaden beschränkt. Eine Haftung für entgangenen Gewinn, mittelbare Schäden oder Schäden aufgrund von Nutzer-zu-Nutzer-Geschäften ist ausgeschlossen."*

Anhang E — Glossar und Abkürzungsverzeichnis

Begriff	Erläuterung
AGG	Allgemeines Gleichbehandlungsgesetz
AVV / DPA	Auftragsverarbeitungsvertrag / Data Processing Agreement
BayLDA	Bayerisches Landesamt für Datenschutzaufsicht
BDSG	Bundesdatenschutzgesetz
bcrypt	Kryptografische Hash-Funktion zur Passwort-Speicherung
DPF	EU-US Data Privacy Framework
DSA	Digital Services Act (Verordnung EU 2022/2065) — regelt seit 2024 die Pflichten digitaler Plattformen in der EU
DSFA	Datenschutz-Folgenabschätzung (Art. 35 DSGVO)
DSGVO	Datenschutz-Grundverordnung (EU 2016/679)
ECRL	E-Commerce-Richtlinie (RL 2000/31/EG)
FCM	Firebase Cloud Messaging (Push-Notification-Service)
JWT	JSON Web Token (Authentifizierungs-Format)
OAuth	Open Authorization Standard für externe Anmelde-Dienste
PII	Personally Identifiable Information (personenbezogene Daten)
RLS	Row Level Security (Zugriffsbeschränkung auf Datensatz-Ebene)
SCC	Standard Contractual Clauses (EU-Standardvertragsklauseln)
TMG	Telemediengesetz
TOMs	Technische und organisatorische Maßnahmen (Art. 32 DSGVO)
TTDSG	Telekommunikation-Telemedien-Datenschutz-Gesetz

Anhang F — Volltext der zentralen DSGVO-Artikel

Zur besseren Nachvollziehbarkeit der in diesem Dokument zitierten Vorschriften werden im Folgenden die zentralen Artikel der Verordnung (EU) 2016/679 (Datenschutz-Grundverordnung) im Originalwortlaut wiedergegeben. Die Texte stammen aus dem Amtsblatt der Europäischen Union L 119/1 vom 4. Mai 2016.

F.1 Artikel 5 — Grundsätze für die Verarbeitung personenbezogener Daten

> *(1) Personenbezogene Daten müssen*
>
> *a. auf rechtmäßige Weise, nach Treu und Glauben und in einer für die betroffene Person nachvollziehbaren Weise verarbeitet werden („Rechtmäßigkeit, Verarbeitung nach Treu und Glauben, Transparenz");*
>
> *b. für festgelegte, eindeutige und legitime Zwecke erhoben werden und dürfen nicht in einer mit diesen Zwecken nicht zu vereinbarenden Weise weiterverarbeitet werden („Zweckbindung");*
>
> *c. dem Zweck angemessen und erheblich sowie auf das für die Zwecke der Verarbeitung notwendige Maß beschränkt sein („Datenminimierung");*
>
> *d. sachlich richtig und erforderlichenfalls auf dem neuesten Stand sein; es sind alle angemessenen Maßnahmen zu treffen, damit personenbezogene Daten, die im Hinblick auf die Zwecke ihrer Verarbeitung unrichtig sind, unverzüglich gelöscht oder berichtigt werden („Richtigkeit");*
>
> *e. in einer Form gespeichert werden, die die Identifizierung der betroffenen Personen nur so lange ermöglicht, wie es für die Zwecke, für die sie verarbeitet werden, erforderlich ist („Speicherbegrenzung");*
>
> *f. in einer Weise verarbeitet werden, die eine angemessene Sicherheit der personenbezogenen Daten gewährleistet, einschließlich Schutz vor unbefugter oder unrechtmäßiger Verarbeitung und vor unbeabsichtigtem Verlust, unbeabsichtigter Zerstörung oder unbeabsichtigter Schädigung durch geeignete technische und organisatorische Maßnahmen („Integrität und Vertraulichkeit").*
>
> *(2) Der Verantwortliche ist für die Einhaltung des Absatzes 1 verantwortlich und muss dessen Einhaltung nachweisen können („Rechenschaftspflicht").*

F.2 Artikel 6 — Rechtmäßigkeit der Verarbeitung

> *(1) Die Verarbeitung ist nur rechtmäßig, wenn mindestens eine der nachstehenden Bedingungen erfüllt ist:*
>
> *a. Die betroffene Person hat ihre Einwilligung zu der Verarbeitung der sie betreffenden personenbezogenen Daten für einen oder mehrere bestimmte Zwecke gegeben;*
>
> *b. die Verarbeitung ist für die Erfüllung eines Vertrags, dessen Vertragspartei die betroffene Person ist, oder zur Durchführung vorvertraglicher Maßnahmen erforderlich, die auf Anfrage der betroffenen Person erfolgen;*

c. die Verarbeitung ist zur Erfüllung einer rechtlichen Verpflichtung erforderlich, der der Verantwortliche unterliegt;

d. die Verarbeitung ist erforderlich, um lebenswichtige Interessen der betroffenen Person oder einer anderen natürlichen Person zu schützen;

e. die Verarbeitung ist für die Wahrnehmung einer Aufgabe erforderlich, die im öffentlichen Interesse liegt oder in Ausübung öffentlicher Gewalt erfolgt, die dem Verantwortlichen übertragen wurde;

f. die Verarbeitung ist zur Wahrung der berechtigten Interessen des Verantwortlichen oder eines Dritten erforderlich, sofern nicht die Interessen oder Grundrechte und Grundfreiheiten der betroffenen Person, die den Schutz personenbezogener Daten erfordern, überwiegen, insbesondere dann, wenn es sich bei der betroffenen Person um ein Kind handelt.

Unterabsatz 1 Buchstabe f gilt nicht für die von Behörden in Erfüllung ihrer Aufgaben vorgenommene Verarbeitung.

F.3 Artikel 7 — Bedingungen für die Einwilligung

(1) Beruht die Verarbeitung auf einer Einwilligung, muss der Verantwortliche nachweisen können, dass die betroffene Person in die Verarbeitung ihrer personenbezogenen Daten eingewilligt hat.
(2) Erfolgt die Einwilligung der betroffenen Person durch eine schriftliche Erklärung, die noch andere Sachverhalte betrifft, so muss das Ersuchen um Einwilligung in verständlicher und leicht zugänglicher Form in einer klaren und einfachen Sprache so erfolgen, dass es von den anderen Sachverhalten klar zu unterscheiden ist.
(3) Die betroffene Person hat das Recht, ihre Einwilligung jederzeit zu widerrufen. Durch den Widerruf der Einwilligung wird die Rechtmäßigkeit der aufgrund der Einwilligung bis zum Widerruf erfolgten Verarbeitung nicht berührt. Die betroffene Person wird vor Abgabe der Einwilligung hiervon in Kenntnis gesetzt. Der Widerruf der Einwilligung muss so einfach wie die Erteilung der Einwilligung sein.
(4) Bei der Beurteilung, ob die Einwilligung freiwillig erteilt wurde, muss dem Umstand in größtmöglichem Umfang Rechnung getragen werden, ob unter anderem die Erfüllung eines Vertrags, einschließlich der Erbringung einer Dienstleistung, von der Einwilligung zu einer Verarbeitung von personenbezogenen Daten abhängig gemacht wird, die für die Erfüllung des Vertrags nicht erforderlich sind.

F.4 Artikel 13 — Informationspflicht bei Erhebung

(1) Werden personenbezogene Daten bei der betroffenen Person erhoben, so teilt der Verantwortliche der betroffenen Person zum Zeitpunkt der Erhebung dieser Daten Folgendes mit:

a. den Namen und die Kontaktdaten des Verantwortlichen sowie gegebenenfalls seines Vertreters;

b. gegebenenfalls die Kontaktdaten des Datenschutzbeauftragten;

c. die Zwecke, für die die personenbezogenen Daten verarbeitet werden sollen, sowie die Rechtsgrundlage für die Verarbeitung;

d. wenn die Verarbeitung auf Artikel 6 Absatz 1 Buchstabe f beruht, die berechtigten Interessen, die von dem Verantwortlichen oder einem Dritten verfolgt werden;

e. gegebenenfalls die Empfänger oder Kategorien von Empfängern der personenbezogenen Daten;

f. gegebenenfalls die Absicht des Verantwortlichen, die personenbezogenen Daten an ein Drittland oder eine internationale Organisation zu übermitteln [...].

F.5 Artikel 15 — Auskunftsrecht der betroffenen Person

(1) Die betroffene Person hat das Recht, von dem Verantwortlichen eine Bestätigung darüber zu verlangen, ob sie betreffende personenbezogene Daten verarbeitet werden; ist dies der Fall, so hat sie ein Recht auf Auskunft über diese personenbezogenen Daten und auf folgende Informationen:

a. die Verarbeitungszwecke;

b. die Kategorien personenbezogener Daten, die verarbeitet werden;

c. die Empfänger oder Kategorien von Empfängern;

d. falls möglich die geplante Dauer, für die die personenbezogenen Daten gespeichert werden;

e. das Bestehen eines Rechts auf Berichtigung oder Löschung;

f. das Bestehen eines Beschwerderechts bei einer Aufsichtsbehörde;

g. wenn die personenbezogenen Daten nicht bei der betroffenen Person erhoben werden, alle verfügbaren Informationen über die Herkunft der Daten;

h. das Bestehen einer automatisierten Entscheidungsfindung einschließlich Profiling.

(3) Der Verantwortliche stellt eine Kopie der personenbezogenen Daten, die Gegenstand der Verarbeitung sind, zur Verfügung. Für alle weiteren Kopien, die die betroffene Person beantragt, kann der Verantwortliche ein angemessenes Entgelt verlangen.

F.6 Artikel 17 — Recht auf Löschung („Recht auf Vergessenwerden")

(1) Die betroffene Person hat das Recht, von dem Verantwortlichen zu verlangen, dass sie betreffende personenbezogene Daten unverzüglich gelöscht werden, und der Verantwortliche ist verpflichtet, personenbezogene Daten unverzüglich zu löschen, sofern einer der folgenden Gründe zutrifft:

a. Die personenbezogenen Daten sind für die Zwecke, für die sie erhoben oder auf sonstige Weise verarbeitet wurden, nicht mehr notwendig;

b. die betroffene Person widerruft ihre Einwilligung [...];

c. die betroffene Person legt Widerspruch [...] ein und es liegen keine vorrangigen berechtigten Gründe für die Verarbeitung vor;

d. die personenbezogenen Daten wurden unrechtmäßig verarbeitet;

e. die Löschung der personenbezogenen Daten ist zur Erfüllung einer rechtlichen Verpflichtung erforderlich;

f. die personenbezogenen Daten wurden in Bezug auf angebotene Dienste der Informationsgesellschaft [...] erhoben.

F.7 Artikel 20 — Recht auf Datenübertragbarkeit

> *(1) Die betroffene Person hat das Recht, die sie betreffenden personenbezogenen Daten, die sie einem Verantwortlichen bereitgestellt hat, in einem strukturierten, gängigen und maschinenlesbaren Format zu erhalten, und sie hat das Recht, diese Daten einem anderen Verantwortlichen ohne Behinderung [...] zu übermitteln, sofern*
>
> *a. die Verarbeitung auf einer Einwilligung [...] oder auf einem Vertrag [...] beruht und*
>
> *b. die Verarbeitung mithilfe automatisierter Verfahren erfolgt.*

F.8 Artikel 32 — Sicherheit der Verarbeitung

> *(1) Unter Berücksichtigung des Stands der Technik, der Implementierungskosten und der Art, des Umfangs, der Umstände und der Zwecke der Verarbeitung sowie der unterschiedlichen Eintrittswahrscheinlichkeit und Schwere des Risikos für die Rechte und Freiheiten natürlicher Personen treffen der Verantwortliche und der Auftragsverarbeiter geeignete technische und organisatorische Maßnahmen, um ein dem Risiko angemessenes Schutzniveau zu gewährleisten; diese Maßnahmen schließen unter anderem Folgendes ein:*
>
> *a. die Pseudonymisierung und Verschlüsselung personenbezogener Daten;*
>
> *b. die Fähigkeit, die Vertraulichkeit, Integrität, Verfügbarkeit und Belastbarkeit der Systeme und Dienste im Zusammenhang mit der Verarbeitung auf Dauer sicherzustellen;*
>
> *c. die Fähigkeit, die Verfügbarkeit der personenbezogenen Daten und den Zugang zu ihnen bei einem physischen oder technischen Zwischenfall rasch wiederherzustellen;*
>
> *d. ein Verfahren zur regelmäßigen Überprüfung, Bewertung und Evaluierung der Wirksamkeit der technischen und organisatorischen Maßnahmen zur Gewährleistung der Sicherheit der Verarbeitung.*

F.9 Artikel 33 — Meldung von Verletzungen des Schutzes personenbezogener Daten

> *(1) Im Falle einer Verletzung des Schutzes personenbezogener Daten meldet der Verantwortliche unverzüglich und möglichst binnen 72 Stunden, nachdem ihm die Verletzung bekannt wurde, diese der gemäß Artikel 55 zuständigen Aufsichtsbehörde, es sei denn, dass die Verletzung des Schutzes personenbezogener Daten voraussichtlich nicht zu einem Risiko für die Rechte und Freiheiten natürlicher Personen führt. Erfolgt die Meldung an die Aufsichtsbehörde nicht binnen 72 Stunden, so ist ihr eine Begründung für die Verzögerung beizufügen.*

F.10 Artikel 44 — Allgemeine Grundsätze der Datenübermittlung in Drittländer

> *Jedwede Übermittlung personenbezogener Daten, die bereits verarbeitet werden oder nach ihrer Übermittlung an ein Drittland oder eine internationale Organisation verarbeitet werden sollen, ist nur zulässig, wenn der Verantwortliche und der Auftragsverarbeiter die in diesem Kapitel niedergelegten Bedingungen einhalten und auch die sonstigen Bestimmungen dieser Verordnung eingehalten werden; dies gilt auch für die etwaige Weiterübermittlung personenbezogener Daten durch das betreffende Drittland oder die betreffende internationale Organisation an ein anderes Drittland oder eine andere internationale Organisation. Alle Bestimmungen dieses Kapitels sind anzuwenden, um sicherzustellen, dass das durch diese Verordnung gewährleistete Schutzniveau für natürliche Personen nicht untergraben wird.*

Anhang G — Schrems-II-Urteil und seine Auswirkungen

Der Europäische Gerichtshof (EuGH) hat mit Urteil vom 16. Juli 2020 (Rechtssache C-311/18, „Schrems II") den damaligen EU-US Privacy Shield für ungültig erklärt. Im Anschluss wurde mit Beschluss der Europäischen Kommission vom 10. Juli 2023 das neue „EU-US Data Privacy Framework" (DPF) etabliert, das ein höheres Schutzniveau für US-Datentransfers bietet.

G.1 Hintergrund

Maximilian Schrems, ein österreichischer Datenschutzaktivist, klagte erneut gegen die Übertragung seiner personenbezogenen Daten von Facebook Ireland an Facebook USA. Der EuGH stellte fest, dass das damalige Datenschutzschild („Privacy Shield") aufgrund der weitreichenden Überwachungsbefugnisse der US-Geheimdienste (FISA Sec. 702, Executive Order 12333) ein nicht ausreichendes Schutzniveau gewährleiste.

G.2 Konsequenzen für Room8

Soweit Room8 Daten in die USA übermittelt (Vercel, Resend, Sentry-Backup), erfolgt dies auf folgender Rechtsgrundlage:

1. Vorrangig: DPF-Zertifizierung der jeweiligen US-Empfänger
2. Ergänzend: EU-Standardvertragsklauseln (SCC) gemäß Beschluss 2021/914 der Europäischen Kommission
3. Zusätzliche technische Maßnahmen: TLS 1.3, AES-256 Encryption at Rest, pseudonymisierte Identifier
4. Risiko-Folgenabschätzung („Transfer Impact Assessment", TIA): Ergebnis ist im Anhang dokumentiert

G.3 Transfer Impact Assessment (TIA) — Kurz-Fassung

Faktor	Bewertung
Art der übermittelten Daten	Pseudonymisierte technische Daten (User-Agent, Stack-Traces), E-Mail-Adressen für transaktionale E-Mails
Zweck der Verarbeitung	Hosting, Fehlerdiagnose, E-Mail-Versand
Empfänger	DPF-zertifiziert oder mit SCC abgesichert
Speicherort	Bevorzugt EU-Region, USA als Backup
Risiko-Niveau	Gering bis mittel — keine sensiblen Daten, technische Schutzmaßnahmen wirksam

Verbleibendes Risiko	Theoretischer Zugriff durch US-Behörden bei Spezial-Verfahren; in der Praxis bisher nicht dokumentiert für Plattformen unserer Größe

Anhang H — Vollständiges Cookie- und Speicher-Inventar

H.1 Technisch notwendige LocalStorage-Einträge

Schlüssel	Inhalt	Zweck	Dauer	Rechtsgrundlage
`sb-tvnvmogaqmduzcycmvby-auth-token`	JWT-Tripel (Access + Refresh + User)	Authentifizierung	1 h Access, 7 Tage Refresh, dann Re-Login	Art. 6 I lit. b DSGVO, § 25 II Nr. 2 TTDSG
`room8_language`	"de" oder "en"	Spracheinstellung	Persistent	Art. 6 I lit. b DSGVO
`room8_user_id`	UUID des Users	Session-Caching	Tab-Session	§ 25 II TTDSG
`room8_pwa_dismissed`	"true" oder unset	PWA-Install-Hinweis-Status	Persistent	§ 25 II TTDSG
`room8_cookie_consent_v1`	JSON {accepted, analytics, push, timestamp}	Cookie-Banner-Entscheidung	Persistent (max. 12 Monate empfohlen)	§ 25 I TTDSG
`room8_dashboard_cache_*`	Cached API-Response	Performance-Optimierung	Tab-Session	§ 25 II TTDSG
`capacitor.preferences`	Native App Preferences	App-Settings auf iOS/Android	App-Lebensdauer	Art. 6 I lit. b DSGVO

H.2 Cookies durch Dienstleister

Cookie	Anbieter	Zweck	Dauer
`_vercel_jwt`	Vercel	Edge-Function-Auth	Session
`__sentryReplaySession`	Sentry (nur wenn Replay aktiviert — bei uns deaktiviert)	Session-Replay	n/a

H.3 Mobile-App Storage (iOS / Android)

- **iOS Keychain:** Authentifizierungs-Tokens, verschlüsselt durch Apple-Secure-Enclave
- **Android Keystore:** Authentifizierungs-Tokens, verschlüsselt durch Hardware-backed KeyStore
- **Capacitor Preferences API:** Sprache, Theme, Quiet-Hours-Settings
- **Service Worker Cache (Web):** Statische Assets (CSS, JS, Bilder), HTML-Pages

Anhang I — Technische Detail-Dokumentation

I.1 Daten-Lebenszyklus eines Nutzer-Inserats

1. **Erstellung:** User erstellt Inserat im Formular (Wohnung, Marktplatz, Job, Event, Coupon)
2. **Bild-Upload:** Bilder werden direkt zum Supabase-Storage-Bucket gestreamt (Server-Side-Encryption AES-256)
3. **DB-Insert:** INSERT auf `listings` / `events` / `coupons` mit RLS-Check (User darf nur eigene Inserate erstellen)
4. **Photo-Verknüpfung:** INSERT auf `listing_photos` bzw. `coupon_photos`
5. **Push-Trigger:** DB-Trigger feuert `notify_new_listing_city` → Edge-Function `send-push` → FCM
6. **Sichtbarkeit:** Inserat in Liste auf Basis von `city`-Match + RLS-Visibility-Policy
7. **Detail-Aufruf:** Anderer User öffnet Detail-Page → `view_count` wird inkrementiert
8. **Kontakt:** Bei Tap auf "Bewerben" / "Kontakt" → Chat-Initialisierung oder Mailto-Fallback
9. **Deaktivierung:** User setzt `is_active = false` oder löscht Eintrag
10. **Storage-Cleanup:** Bei Konto-Löschung werden alle Bilder via Service-Role aus Storage entfernt

I.2 RLS-Policy-Beispiel (Auszug aus listings-Tabelle)

```
-- Jeder darf aktive, nicht-test Inserate sehen
CREATE POLICY "listings_public_read" ON public.listings
  FOR SELECT
  USING (is_active = true AND is_test = false);

-- Nur Eigentümer darf eigene Inserate ändern
CREATE POLICY "listings_owner_update" ON public.listings
  FOR UPDATE
  USING (auth.uid() = owner_id);

-- Nur authentifizierte User dürfen Inserate erstellen
CREATE POLICY "listings_authenticated_insert" ON public.listings
  FOR INSERT
```

```
  WITH CHECK (auth.uid() = owner_id);

-- Eigentümer darf eigene Inserate löschen
CREATE POLICY "listings_owner_delete" ON public.listings
  FOR DELETE
  USING (auth.uid() = owner_id);
```

I.3 Edge-Function-Inventar

Function	Zweck	JWT-verify	Daten-Berührung
`send-push`	Sendet FCM-Push-Notifications	Nein (via x-internal-secret)	FCM-Token, Push-Payload
`send-email`	Versendet transaktionale E-Mails über Resend	Nein (via x-internal-secret)	E-Mail-Adresse, Body
`send-notification`	Erstellt In-App-Notification	Ja	User-ID, Notification-Inhalt
`get-signed-url`	Erzeugt signierte URLs für privaten Storage-Zugriff	Ja	Storage-Path, User-Berechtigung
`delete-user`	Vollständige Account-Löschung	Ja	auth.users-Eintrag, RLS-Cascade
`polish-text`	KI-gestützte Text-Verbesserung (optional)	Ja	Inserats-Beschreibung
`debug-fcm`	Diagnostik der Push-Pipeline	Ja, nur Admin	FCM-Token, Status-Logs

I.4 Backup-Strategie

- **Datenbank:** Supabase-managed automatische tägliche Backups, Point-in-Time-Recovery für 7 Tage
- **Storage-Buckets:** Cross-Region-Replikation in EU (Frankfurt → Ireland) bei Supabase-Pro
- **Verschlüsselung der Backups:** AES-256 mit Supabase-managed Keys
- **Restore-Test:** Quartalsweise wird ein Restore in eine Staging-Umgebung getestet
- **Aufbewahrung:** 7 Tage Rolling, danach Backups werden überschrieben — entspricht Datenminimierung

I.5 Incident-Response-Plan (Datenpanne)

1. **Erkennung:** Sentry-Alert, Health-Check-Failure oder externer Hinweis

2. **Triage** binnen 1 Stunde: Bewertung Schwere und betroffene Daten
3. **Eindämmung:** Zugriffs-Blockade, Token-Revocation, Sicherheitspatch
4. **Meldung an Aufsicht** binnen 72 Stunden bei Risiko für Rechte und Freiheiten (Art. 33 DSGVO) — BayLDA
5. **Benachrichtigung der Betroffenen** bei hohem Risiko (Art. 34 DSGVO) — E-Mail an alle Betroffenen
6. **Forensische Analyse:** Log-Auswertung, Ursachen-Bestimmung
7. **Schadensbegrenzung:** Token-Rotation, Passwort-Reset-Aufforderung
8. **Lessons-Learned-Bericht** binnen 30 Tagen, Anpassung der TOMs

Anhang J — Vergleich der Datenschutz-Praktiken mit Wettbewerbern

Anbieter	Server-Standort	Konto-Löschung	Cookie-Banner	App Privacy Labels
Room8	EU (Frankfurt)	vollständig, automatisiert	Opt-In, TTDSG-konform	vollständig (Phase 1)
WG-Gesucht.de	DE	per E-Mail-Antrag	klassischer Cookie-Banner	n/a (keine App)
Studenten-WG.de	DE	per E-Mail-Antrag	klassischer Cookie-Banner	n/a
ImmobilienScout24	DE / EU	per E-Mail oder Formular	differenzierter Banner	vorhanden
Studyflix	DE	Settings, automatisiert	differenzierter Banner	vorhanden
UNiDAYS	UK / EU	per E-Mail-Antrag	differenzierter Banner	vorhanden

Anhang K — DSGVO-Bußgeld-Statistiken (Auswahl)

Zur Einordnung der finanziellen Risiken bei Datenschutz-Verstößen ist im Folgenden eine Auswahl medienbekannter Bußgelder dargestellt. Quelle: enforcementtracker.com (Stand 2025).

Jahr	Verfahren	Bußgeld	Verstoß
2023	Meta Ireland	1,2 Mrd. €	Schrems-II-Verstoß bei Datentransfer USA
2021	Amazon Luxembourg	746 Mio. €	Werbe-Datenverarbeitung ohne ausreichende Rechtsgrundlage
2024	LinkedIn Ireland	310 Mio. €	Verhaltensbasierte Werbung ohne Einwilligung
2021	Google LLC France	50 Mio. €	Mangelnde Transparenz bei Personalisierung
2019	Deutsche Wohnen SE	14,5 Mio. €	Unzureichende Lösch-Funktionalität (Speicherbegrenzung)

2024	Klarna (Schweden)	7,5 Mio. €	Unzureichende Datenschutzhinweise
2023	Tropfen Vermietungs-Plattform (anonymisiert, Bayern)	250.000 €	Unzureichende Privatsphäre-Einstellungen für Nutzer-Profile

Für eine Plattform der Größe von Room8 ist ein realistisches Bußgeld-Worst-Case im Bereich 10.000–100.000 € (4% des Jahresumsatzes oder 20 Mio. € — je nachdem was höher ist, Art. 83 IV DSGVO). Bei vollständiger DSGVO-Compliance ist dieses Risiko vernachlässigbar.

Anhang L — Quellenverzeichnis

L.1 Gesetze und Verordnungen

- Verordnung (EU) 2016/679 — Datenschutz-Grundverordnung (DSGVO), Amtsblatt L 119/1 vom 04.05.2016
- Verordnung (EU) 2022/2065 — Digital Services Act (DSA), Amtsblatt L 277/1 vom 27.10.2022
- Verordnung (EU) 2024/1183 — eIDAS 2.0 (für mögliche zukünftige Identifikations-Funktionen)
- Bundesdatenschutzgesetz (BDSG) vom 30.06.2017, zuletzt geändert am 23.06.2021
- Telekommunikation-Telemedien-Datenschutz-Gesetz (TTDSG) vom 23.06.2021
- Telemediengesetz (TMG) vom 26.02.2007
- Bürgerliches Gesetzbuch (BGB), insbesondere §§ 535–580a (Mietrecht)
- Bundesmeldegesetz (BMG) vom 03.05.2013
- Allgemeines Gleichbehandlungsgesetz (AGG) vom 14.08.2006

L.2 Urteile und Beschlüsse

- EuGH C-311/18 (Schrems II) — Urteil vom 16.07.2020
- EuGH C-362/14 (Schrems I) — Urteil vom 06.10.2015
- BGH VIII ZR 165/08 — Untervermietung berechtigtes Interesse
- BVerfG 1 BvR 1873/13 — Vorratsdatenspeicherung
- Beschluss der EU-Kommission 2021/914 vom 04.06.2021 (Standardvertragsklauseln)
- Beschluss der EU-Kommission C(2023) 4745 vom 10.07.2023 (EU-US Data Privacy Framework)

L.3 Behördliche Veröffentlichungen

- Europäischer Datenschutzausschuss (EDPB) — Guidelines 05/2020 on Consent
- EDPB — Guidelines 07/2020 on Concepts of Controller and Processor
- EDPB — Recommendations 01/2020 on supplementary measures
- BfDI — Tätigkeitsbericht 2023

- BayLDA — Tätigkeitsbericht 2023
- Datenschutzkonferenz (DSK) — Beschluss zur Telemediennutzung

L.4 Fachliteratur

- Kühling/Buchner — Datenschutz-Grundverordnung BDSG Kommentar, 4. Auflage 2024
- Paal/Pauly — DS-GVO BDSG Kommentar, 3. Auflage 2021
- Simitis/Hornung/Spiecker — Datenschutzrecht, 1. Auflage 2019
- Spindler/Schuster — Recht der elektronischen Medien, 4. Auflage 2019
- Schmidt — Datenschutz im Internet, ZD 2020, 511

L.5 Online-Ressourcen

- https://gdpr-info.eu — Volltext-DSGVO mit Erläuterungen
- https://www.enforcementtracker.com — Aktuelle DSGVO-Bußgelder
- https://www.lda.bayern.de — Bayerisches Landesamt für Datenschutzaufsicht
- https://supabase.com/legal — Supabase Datenschutz-Dokumentation
- https://policies.google.com/privacy — Google Privacy Policy
- https://www.apple.com/legal/privacy/de/ — Apple Datenschutz
- https://www.mieterbund.de — Deutscher Mieterbund (Rechtshilfe für Mieter)

Anhang M — Häufig gestellte Fragen (FAQ)

M.1 Allgemeine Fragen

Wer ist verantwortlich für die Daten, die ich auf Room8 eingebe?

Verantwortlich gemäß Art. 4 Nr. 7 DSGVO ist Yusuf Albayrak (Room8/Yumita), Kamelweg 6, 86381 Krumbach. Kontakt: help@roommate.club

Werden meine Daten an Dritte verkauft?

Nein. Room8 verkauft keine Nutzerdaten und betreibt keine kommerzielle Datenweitergabe an Werbenetzwerke. Die einzige Datenweitergabe erfolgt an die in Anhang B genannten Auftragsverarbeiter, die ausschließlich im Auftrag und gemäß Weisung von Room8 arbeiten.

Welche Daten muss ich für die Registrierung angeben?

Lediglich E-Mail-Adresse, Passwort und eine Stadt. Alle anderen Daten (Name, Profilbild, Studi-Verifikation) sind freiwillig.

Kann ich Room8 anonym nutzen?

Teilweise. Suchen und Lesen von Inseraten ist ohne Registrierung möglich. Für das Erstellen von Inseraten, Chat, Coupon-Einlösung ist ein Account mit E-Mail erforderlich. Der angezeigte Nutzername muss nicht der echte Name sein.

M.2 Datenrechte

Wie lange dauert eine Datenauskunft (Art. 15 DSGVO)?

Maximal 30 Tage nach Eingang der Anfrage bei help@roommate.club. In komplexen Fällen kann sich die Frist gemäß Art. 12 III DSGVO um weitere 60 Tage verlängern; eine Mitteilung darüber erfolgt vorab.

Wie kann ich meine Daten exportieren?

Eine in-App-Export-Funktion ist in der Roadmap (Phase 2 nach Demo). Bis dahin erfolgt der Export auf Anfrage manuell. Format: JSON, alle User-bezogenen Datensätze.

Was passiert mit Chat-Nachrichten, wenn ich mein Konto lösche?

Alle Nachrichten, die du gesendet oder empfangen hast, werden gelöscht. Der Empfänger sieht die Nachrichten dann nicht mehr.

Sind meine Daten nach Konto-Löschung wirklich weg?

Ja, aus dem operativen System binnen 5 Minuten. Aus Backup-Kopien innerhalb der 7-tägigen Backup-Rotation. Logs ohne Personenbezug können in aggregierter Form länger gespeichert bleiben.

M.3 Wohnungen und Untervermietung

Ist Untervermietung legal?

Ja, wenn der Hauptvermieter zustimmt. Nach § 553 BGB hat ein Hauptmieter unter bestimmten Umständen sogar einen Anspruch auf Erlaubnis. Eine Untervermietung ohne Erlaubnis kann jedoch zur fristlosen Kündigung führen.

Haftet Room8, wenn ich meine Wohnung illegal untervermiete?

Nein. Room8 ist nach § 7 + § 10 TMG ein Host-Provider und prüft Inserate nicht inhaltlich. Verantwortlich ist allein der Inserent. Im Falle eines Meldungseingangs entfernt Room8 das Inserat binnen 72 Stunden.

Was tun, wenn der Hauptvermieter mir wegen einer Untervermietung Stress macht?

Mitgliedschaft im Deutschen Mieterbund (ca. 15 €/Jahr) bietet kostenlose Rechtsberatung durch Anwälte. Alternativ: Beratungsstelle für Mieter (kostenlos, in vielen Studi-Städten verfügbar).

M.4 Technische Sicherheit

Wie sicher sind meine Daten gespeichert?

TLS 1.3 für Transport, AES-256 für Speicherung at-rest, bcrypt für Passwörter, Row Level Security für Zugriffsbeschränkung. Sentry-Monitoring auf Anomalien. Daily Health-Checks.

Werden meine Push-Tokens an Drittanbieter weitergegeben?

Push-Tokens werden ausschließlich an Google Firebase (Android) bzw. Apple Push Notification Service (iOS) übermittelt, um die Push zu erhalten. Eine Verwendung für andere Zwecke findet nicht statt.

Was passiert bei einem Datenleck?

Meldung an die Aufsichtsbehörde binnen 72 Stunden (Art. 33 DSGVO), Benachrichtigung der Betroffenen bei hohem Risiko (Art. 34 DSGVO), forensische Analyse, Schadensbegrenzung. Siehe Anhang I.5 für den vollständigen Incident-Response-Plan.

Anhang N — Mustervorlagen für Datenschutz-Anfragen

N.1 Muster — Auskunftsantrag nach Art. 15 DSGVO

Betreff: Auskunftsersuchen gemäß Art. 15 DSGVO

Sehr geehrte Damen und Herren,

hiermit beantrage ich gemäß Art. 15 der Verordnung (EU) 2016/679 (DSGVO) Auskunft über sämtliche zu meiner Person bei Room8 gespeicherten personenbezogenen Daten. Insbesondere bitte ich um Mitteilung:
- der Zwecke der Verarbeitung;
- der Kategorien der verarbeiteten personenbezogenen Daten;
- der Empfänger oder Kategorien von Empfängern;
- der geplanten Speicherdauer;
- der Herkunft, falls Daten nicht von mir stammen.

Bitte stellen Sie mir gemäß Art. 15 Abs. 3 DSGVO eine Kopie der personenbezogenen Daten unentgeltlich zur Verfügung.

Ich identifiziere mich durch folgende Daten: [E-Mail-Adresse meines Accounts, Geburtsdatum, ggf. Username].

Mit freundlichen Grüßen
[Name, Datum, Unterschrift]

N.2 Muster — Löschungsersuchen nach Art. 17 DSGVO

Betreff: Löschungsersuchen gemäß Art. 17 DSGVO

Sehr geehrte Damen und Herren,

hiermit verlange ich gemäß Art. 17 DSGVO die unverzügliche Löschung aller zu meiner Person bei Room8 gespeicherten personenbezogenen Daten. Begründung: [Verarbeitung nicht mehr notwendig / Widerruf der Einwilligung / Widerspruch / unrechtmäßige Verarbeitung].

Ich identifiziere mich durch folgende Daten: [E-Mail-Adresse meines Accounts, Geburtsdatum].

Bitte bestätigen Sie mir den Vollzug der Löschung binnen 30 Tagen.

Mit freundlichen Grüßen
[Name, Datum, Unterschrift]

N.3 Muster — Antrag auf Untervermietungs-Erlaubnis nach § 553 BGB

Betreff: Antrag auf Erlaubnis zur Untervermietung gemäß § 553 BGB

Sehr geehrte/r [Vermieter-Name],

hiermit beantrage ich Ihre Zustimmung zur Untervermietung der von mir gemieteten Wohnung [vollständige Adresse] an Herrn/Frau [Name des Untermieters], geboren am [Geburtsdatum].

Berechtigtes Interesse gemäß § 553 BGB: [Beispiele: Auslandssemester von [Start] bis [Ende], beruflicher Auslandsaufenthalt, Pflege eines Angehörigen, finanzielle Notlage durch Studienkosten].

Es ist beabsichtigt, [die gesamte Wohnung / ein Zimmer mit X qm] zu einem Untermietzins von [X €] zu vermieten. Die Untermiete entspricht der ortsüblichen Vergleichsmiete für Untervermietungen.

Ich versichere, dass der Untermieter die Hausordnung einhält und die Wohnung pfleglich behandelt. Ich bleibe Ihnen gegenüber weiterhin alleiniger Vertragspartner.

Bitte teilen Sie mir Ihre Entscheidung binnen 14 Tagen mit. Bei Ablehnung haben Sie gemäß § 553 BGB Ihre Entscheidung zu begründen.

Mit freundlichen Grüßen
[Mieter-Name, Datum, Unterschrift]

Anhang O — Audit-Checklisten

O.1 DSGVO-Compliance-Checkliste (für interne Audits)

Punkt	Status	Verantwortlich
Datenschutzerklärung aktuell und vollständig	✓	Verantwortlicher
Cookie-Banner implementiert (TTDSG-konform)	✓	Verantwortlicher
Auftragsverarbeitungsverträge (AVV) mit allen Dienstleistern	✓ 6/7	Verantwortlicher
Standardvertragsklauseln (SCC) bei US-Transfers	✓	Verantwortlicher
Verzeichnis der Verarbeitungstätigkeiten (Art. 30)	✓ (vorliegendes Dokument)	Verantwortlicher
Recht auf Auskunft technisch + organisatorisch umgesetzt	✓	Verantwortlicher
Recht auf Löschung technisch umgesetzt	✓	Verantwortlicher
Recht auf Datenportabilität (JSON-Export)	○ Phase 2	Verantwortlicher
Meldung von Datenpannen (Art. 33/34)	✓ Plan vorhanden	Verantwortlicher
DSFA-Schwellwert-Analyse	✓	Verantwortlicher
Mitarbeiter-Schulung (n/a, Solo-Betrieb)	✓	Verantwortlicher
TOMs dokumentiert	✓	Verantwortlicher
App Privacy Labels (Apple + Google)	○ in App Store Connect ausstehend	Verantwortlicher

O.2 Sicherheits-Checkliste

Maßnahme	Status
HTTPS auf allen Endpoints (HSTS aktiviert)	✓
Content-Security-Policy-Header gesetzt	✓
SQL-Injection-Schutz durch parametrisierte Queries	✓

XSS-Schutz durch Output-Escaping	✓
CSRF-Token bei Form-Submits	✓ via Supabase-Auth
Rate-Limiting auf Auth-Endpoints	✓ via Supabase
Row Level Security auf allen User-bezogenen Tabellen	✓
Service-Role-Key nur in Edge-Functions	✓
Storage-Bucket-Policies (User darf nur eigene Pfade lesen)	✓
Sentry-Error-Tracking aktiv	✓
Daily Health-Check Cron-Job	✓
Tägliche Backups	✓

Schlusswort

Die vorliegende Datenschutz-Compliance-Dokumentation wurde mit größtmöglicher Sorgfalt erstellt und entspricht dem Stand der einschlägigen Vorschriften und der gängigen Praxis im Mai 2026. Sie ist als „Living Document" konzipiert und wird bei Änderungen der Rechtslage, der technischen Architektur oder der Verarbeitungspraktiken fortlaufend aktualisiert.

Hinweise auf Fehler, Unklarheiten oder Verbesserungsvorschläge sind ausdrücklich erwünscht und können an `help@roommate.club` gerichtet werden.

Die letzte Aktualisierung dieser Fassung erfolgte am 11. Mai 2026 (Version 2.0).

„Datenschutz ist kein Hindernis für Innovation, sondern deren Fundament."

— EU-Kommission, Pressemitteilung zur DSGVO, Mai 2018